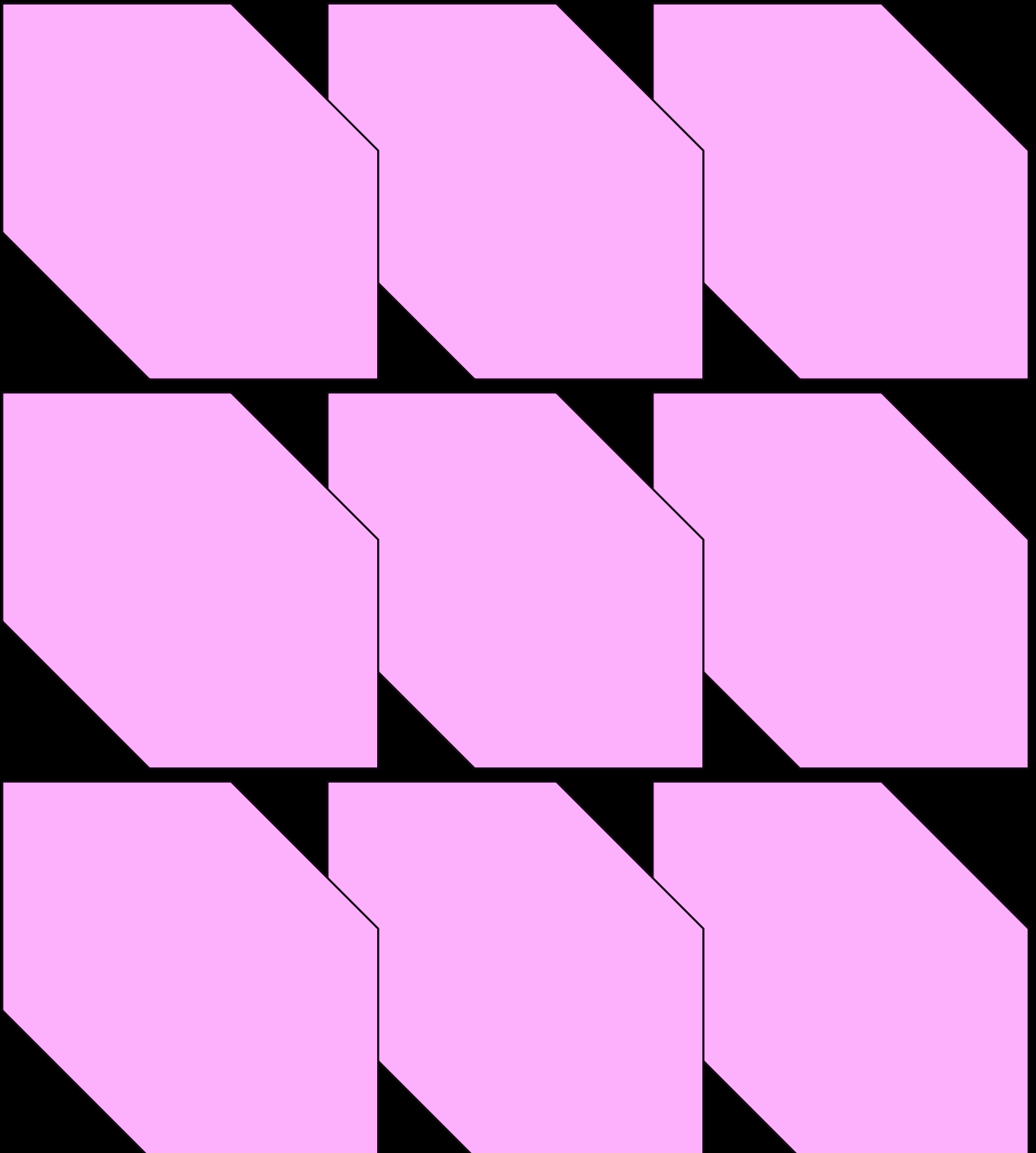




Making Your Website GDPR Compliant



Introduction

Ensuring your website is GDPR compliant is more than a legal requirement. It protects personal data, builds trust, and demonstrates your business values privacy. Compliance is not about complex legal language but about practical measures every website owner can apply. This guide outlines the ten key components of GDPR compliance and gives you a checklist for each one, so you can review your own site step by step. Use it to identify gaps, strengthen processes, and show your visitors that their information is safe in your hands.

In this guide, we will cover:

01 Basis for Data Processing

02 Privacy Policy

03 Cookies & Tracking

04 Data Collection Forms

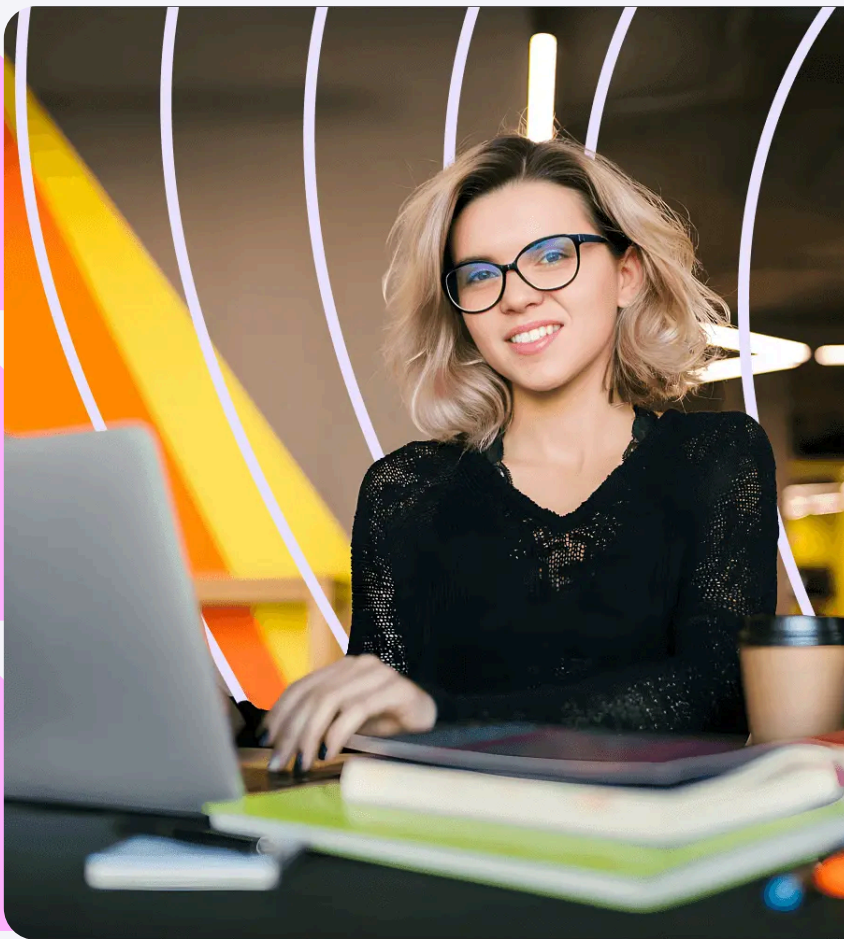
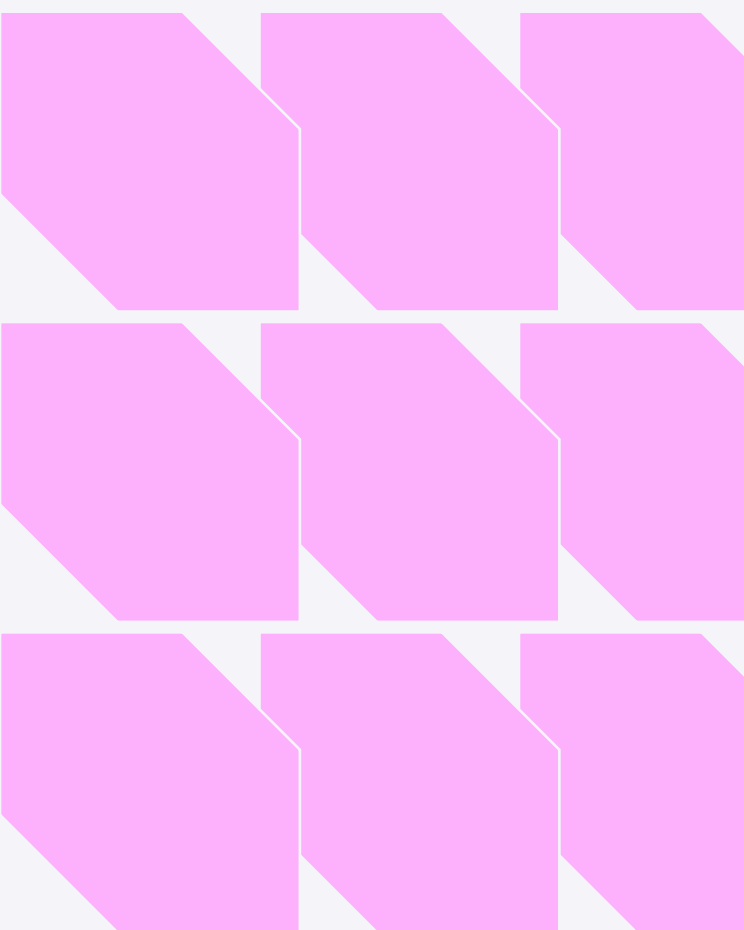
05 Security Measures

06 Data Subject Rights

07 Third-Party Services

08 Breach preparedness

09 Record Keeping



01

Lawful basis for data processing

Your business must have a valid reason to process personal data. GDPR identifies six lawful bases, the most common for websites being consent, contract, and legitimate interests. Choosing the right basis depends on context: for example, a user submitting a contact form may be covered by legitimate interest or contract, while signing up for marketing emails requires explicit consent. Documenting your decisions is essential, as regulators can request evidence. Equally important is limiting the data collected to only what is necessary, demonstrating proportionality and minimisation.

Compliance checks:

- ☐ We have identified and documented the lawful basis for each type of data we process.
- ☐ We only collect the minimum data needed for the purpose stated.
- ☐ We can explain to users why their data is being collected.

02

Privacy policy

A privacy policy is the foundation of transparency. It should clearly state what personal data you collect, why you collect it, how long it is kept, and who it is shared with. It must also explain users' rights under GDPR, such as access, erasure, and objection. The language should be plain and accessible, avoiding unnecessary legal jargon. Including contact details for your data controller or Data Protection Officer is strongly advised. A good privacy policy not only supports compliance but reassures visitors that their data is treated with respect.

Compliance checks:

- ☐ Our privacy policy is easy to find on the website.
- ☐ It explains what data we collect, why, and how long it is kept.
- ☐ It outlines user rights and provides clear contact information.

03

Cookie & tracking controls

Cookies are a common area of GDPR non-compliance. Essential cookies may be set without consent, but analytics, advertising, and personalisation cookies require prior opt-in. A compliant website must display a cookie banner that blocks non-essential cookies until consent is given. The banner should allow users to accept, reject, or choose categories of cookies, and provide a way to withdraw consent at any time. Failing to manage cookies properly is one of the most visible compliance risks and is frequently scrutinised by regulators.

Compliance checks:

- ☐ Our site blocks non-essential cookies until consent is given.
- ☐ Users can choose which categories of cookies to accept.
- ☐ Consent can be withdrawn or changed at any time.

04

Data collection forms

Forms are a critical point of data collection. To comply with GDPR, you must explain why the information is needed and gain consent where appropriate. Checkboxes must not be pre-ticked, and fields should be limited to essentials. For example, if a phone number is not required to respond to an enquiry, it should be optional. If you use data for multiple purposes, each requires separate consent. Making forms transparent and minimal not only reduces compliance risk but also improves the user experience.

Compliance checks:

- ☐ Every form includes clear information on why data is collected.
- ☐ Consent checkboxes are never pre-ticked.
- ☐ Only essential data is requested; optional fields are clearly marked.

05

Security measures

GDPR requires businesses to take appropriate security measures to protect personal data. At minimum, this means ensuring your website runs over HTTPS, that data is encrypted at rest and in transit, and that access is controlled. Security also involves maintaining up-to-date software and monitoring for vulnerabilities. The level of protection should be proportionate to the data you handle: sensitive data requires stronger safeguards. Demonstrating that you take security seriously protects both your customers and your reputation.

Compliance checks:

- ☐ The website uses SSL/TLS encryption (HTTPS).
- ☐ Personal data is encrypted and access is restricted.
- ☐ Software and plugins are updated regularly.

06

Data subject rights management

One of GDPR's most significant changes is granting individuals rights over their data. These include access, rectification, erasure, restriction, and portability. Your website must provide an easy way for users to exercise these rights, and requests must be addressed within one month. Processes should be in place to verify identity before fulfilling requests. Having clear procedures not only ensures compliance but also strengthens user trust, as visitors know they are in control of their personal data.

Compliance checks:

- ☐ We provide a clear way for users to submit data rights requests.
- ☐ We have a process to verify identity before acting on requests.
- ☐ Requests are logged and responded to within one month.

07

Third-party services and processors

Websites often rely on third parties for hosting, analytics, payments, or marketing. Under GDPR, you remain accountable for how those providers process personal data. You must have data processing agreements in place and ensure that data transferred outside the UK or EU is protected with approved safeguards. Reviewing your suppliers helps reduce risk and ensures that your data handling standards are consistently applied across your operations.



Compliance checks:



We have contracts with all third-party processors handling personal data.



We know whether data is transferred outside the UK/EU and have safeguards in place.



We review third-party compliance regularly.

08

Breach preparedness

Even with strong safeguards, data breaches can happen. GDPR requires certain breaches to be reported within 72 hours, so preparation is essential. You should define what constitutes a breach, assign responsibility for managing incidents, and have a plan for investigating and containing risks. Training staff on how to recognise and report issues is equally important. Being prepared reduces impact, helps you meet reporting obligations, and demonstrates accountability.



Compliance checks:



We have a process for identifying and reporting breaches.



Responsibilities for handling incidents are clearly assigned.



Staff are trained to recognise and report potential breaches.

Record keeping & accountability

The final element of compliance is being able to prove it. GDPR requires organisations to keep records of processing activities, document lawful bases, and complete data protection impact assessments when necessary. Even small businesses benefit from documenting their decisions, as it provides evidence of compliance if challenged. Accountability is a core GDPR principle, and keeping records demonstrates that your business takes privacy obligations seriously.



Compliance checks:



We maintain records of data processing activities.



Lawful bases are documented for all processing.



We carry out data protection impact assessments where needed.

Extra

Children's data (if applicable)

If your website targets or collects information from children under 16, additional safeguards apply. Parental consent must be obtained before processing data, and policies should be written in clear, simple language. If your services are not aimed at children, stating this explicitly can also help demonstrate compliance. Mismanaging children's data is taken very seriously by regulators and can result in severe penalties, so it is important to assess whether this area applies to your site.



Compliance checks:



We have identified whether children use our website or services.



Parental consent mechanisms are in place where required.



Our privacy policy explains clearly whether the site is aimed at children.

Want to get in touch?

If you want to find out more about 80five and how we can help you create an unforgettable website for your business, you can find out more on our website, call us, or drop us an email.



01392 949168



hello@80five.co.uk

